Cloud Security Posture Management

Master Template – Remediation SOP

Cloud Configuration Findings

Field	Details
Version	1.1
Owner	Cloud Security Team
Last Updated	03 February 2026
Review Cycle	Quarterly
Audience	Application Teams · Cloud Platform · Cloud Security
Tooling	Wiz (Default & Custom Rules)
Compliance	CSA CCM v4.0.5 → Cloud Security Navigator (CSN) → Wiz rule

Table of Contents

1. Purpose

This document explains how cloud configuration findings should be reviewed and remediated when identified in Wiz. It is a shared component referenced by all control-specific runbooks — it defines the common process so individual runbooks only need to cover what is specific to each control.

We aim to make remediation:

- ☑ Easy to understand
- ☑ Consistent across teams
- ☑ Safe for applications
- ☑ Aligned with CSA / CCM expectations

2. Scope

This template applies to:

- All cloud configuration findings from Wiz (default and custom rules)
- All Cargill AWS environments (prod, stage and dev)
- All application teams and cloud platform teams — each team is responsible for their own resources

ⓘ This template does not prescribe one remediation method. Different applications may handle the same finding differently based on context. Refer to the relevant control-specific runbook for guidance tailored to each control.

3. Guiding Principles (Read This First)

Not every finding means "fix it immediately."
Before making changes, ask:

- Is this resource still active?
- Is the configuration intentional?
- What is the impact of changing it?
- Are there existing compensating controls?

Goal: Secure and functional — not "green at all costs."

⚠ **If you are unsure at any point:** pause and ask Cloud Security before changing anything. Ask early, document decisions, and prioritize application stability alongside security.

4. Roles & Responsibilities

Role	What They Do
Wiz Platform	Detects and reports findings
Cloud Security	Provides guidance and clarification · Tracks control alignment · Tracks remediation metrics · Approves exceptions
Application / Cloud Platform Team	Reviews findings · Implements remediation · Files exceptions where needed · Updates Finding Management Tool

RACI & Escalation: For detailed responsibility assignments and escalation paths, contact the Cloud Security Team. Exception approvals must go through Cloud Security before being logged in the Finding Management Tool.

5. Process Overview

Figure 1 below provides an end-to-end view of the cloud configuration finding remediation workflow — from detection in Wiz through to validation and closure. Refer to this diagram when navigating an unfamiliar finding.

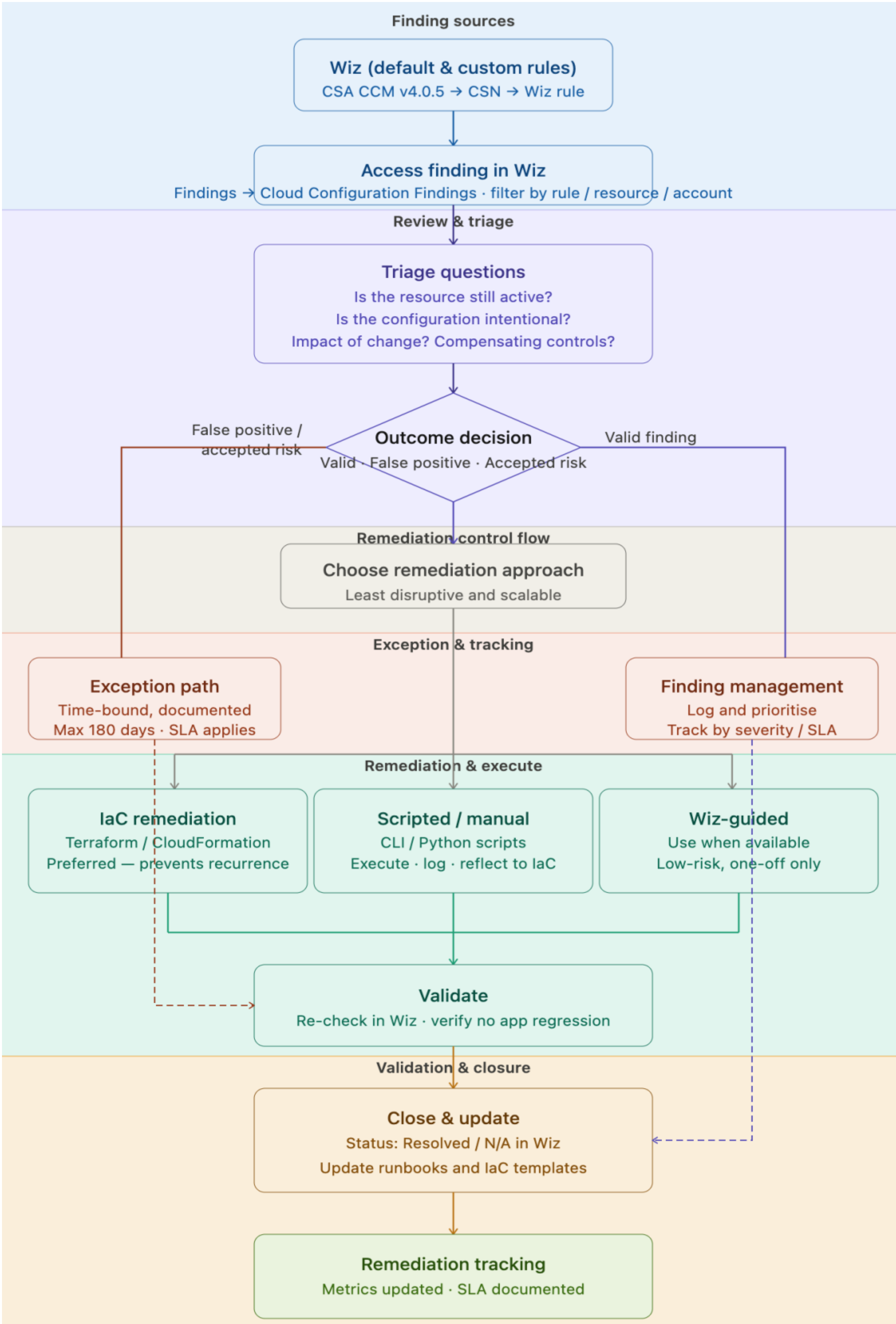

Figure 1 — End-to-end Cloud Configuration Finding Remediation Workflow

6. Access Cloud Configuration Findings

1. [Log in to Wiz]
2. Go to: Findings → [Cloud Configuration Findings]
3. Find the issue / non-compliant rule using: Rule name and/or Resource name and/or Account / subscription
4. Open the rule to see:
   - Affected resource(s)
   - Why it was flagged
   - Evidence and timestamps
   - Suggested fix (if available)

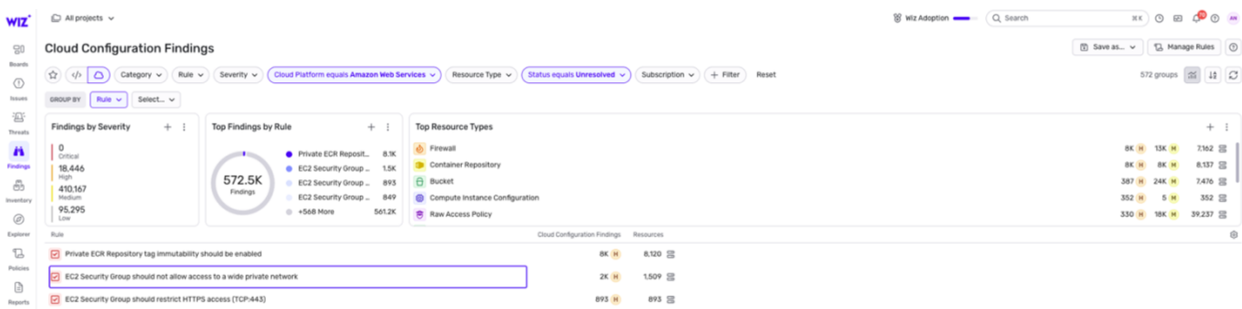

Figure 2 — Cloud Configuration Findings — filtered view showing mis-configurations grouped by rule

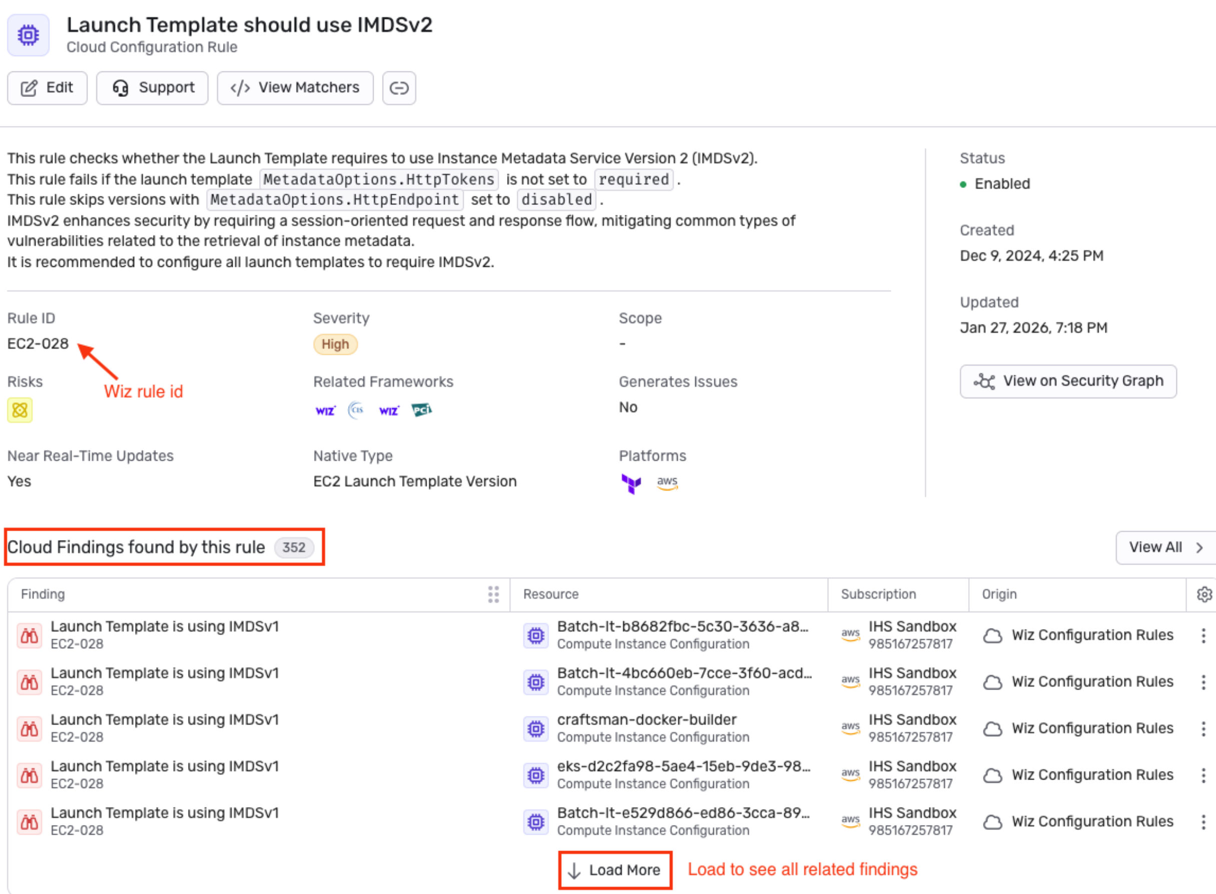

Figure 3 — Rule detail view showing affected resources, description, and evidence

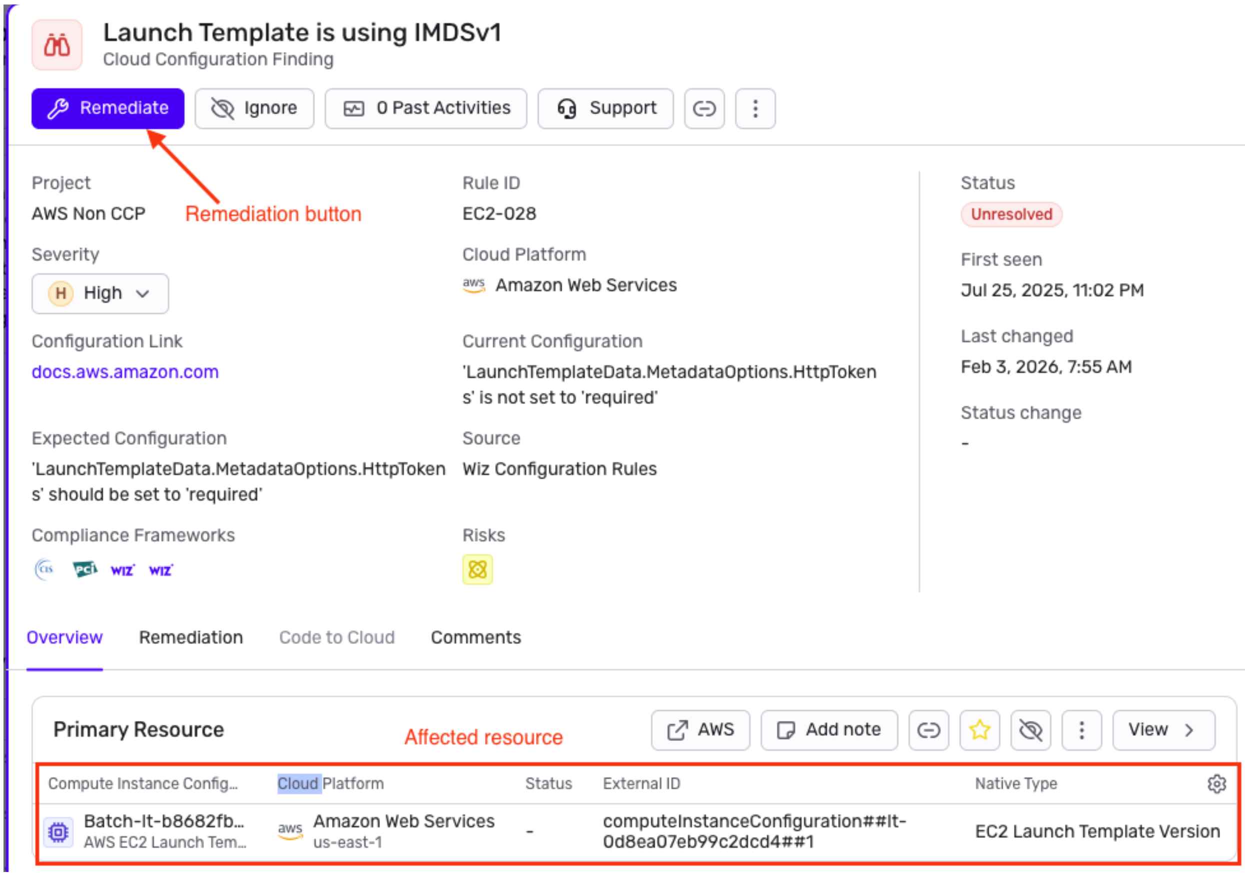

Figure 4 — Resource-level remediation view: Findings → Cloud Configuration Findings → Rule → Affected Resource → Remediate

6.1 Using Mika AI to Simplify Control and Finding Insights

Enter the following prompt into Mika AI one step at a time. Mika does not support bulk requests.

```
Identify the cloud configuration finding for:

Control: <CONTROL_NAME>
Finding: <FINDING_NAME>
Resource: <RESOURCE_ID / NAME>

1. What is misconfigured (simple + technical explanation)
2. Why this is a security risk and what could happen if exploited (real-world
impact)
```

7. Remediation Review & Triage

Review findings and prioritize remediation based on risk, impact, and environment using the Finding Management Tool.

Before acting, ask:

- Is the resource still active?
- Is the configuration intentional?
- Does this match the application design?
- Is there an approved exception?

7.1 Remediation Prioritization by Severity

Use the following as a guide for expected remediation timelines. Final prioritization should account for environment (prod takes precedence), business impact, and any compensating controls already in place.

Severity	Timeline	Guidance
Critical	Immediate	Address within 8 hours. Escalate to Cloud Security immediately if unable to remediate.
High	Short-term	Address within 24 - 48 days. Notify Cloud Security if blocked.
Medium	Planned	Address within 5 days or next sprint cycle.
Low	Backlog	Address within 10 days. Document if deferring.

7.2 Possible Outcomes

Outcome	Action	Where to Go
Valid finding	Plan and implement remediation	Refer to the control-specific runbook. Use the Finding Management Tool to track progress.
False positive	Document and file an exception	→ Wiz CSPM Exception Governance
Accepted risk	Document, time-bound, and track	Log in the Finding Management Tool with justification and expiration date. Must be reviewed at each cycle.

8. Choosing a Remediation Approach

No single method is required — use what fits your application and environment. Use the table below to select the appropriate approach.

Approach	When to Use	Notes
Infrastructure as Code (IaC)	Preferred approach for any resource managed in Terraform or CloudFormation	Ensures changes are version-controlled, peer-reviewed, and repeatable. Prevents config drift.
Wiz-guided Remediation	Available for select controls with low risk and no IaC dependency	Use only when Wiz offers a guided fix and the change has been validated as safe for the environment.
Scripted Remediation	Bulk remediation across many accounts or resources	Scripts must be stored in the approved repository. Do not use ad-hoc scripts without Cloud Security review.
Manual (Console / CLI)	One-off or urgent remediations only	Always reflect manual changes back into IaC to avoid drift. Flag in the Finding Management Tool if IaC update is deferred.

⚠ Reflect manual changes back into IaC as soon as possible. Manual changes not reflected in IaC within 30 days should be flagged as drift in the Finding Management Tool.

9. Exception Process

An exception is required when a finding cannot be remediated due to a legitimate business reason, is a confirmed false positive, or represents an accepted risk that is formally documented and time-bound.

Exception Process: All exceptions must be submitted and approved through the formal exception governance process. Do not mark findings as accepted risk without a logged, approved exception.

→ Wiz CSPM Exception Governance

Every exception must include at minimum:

- Business justification
- Approver name and approval date (Cloud Security approval required)
- Exception expiration date (maximum 180 days — must be reviewed and renewed)
- Compensating controls in place

10. Validation & Closure

After implementing a fix, verify success before closing the finding:

☐	Re-check the resource in Wiz and confirm the finding status is Resolved or No longer applicable.
☐	Verify no application regression occurred following the change.
☐	Update documentation if necessary (runbooks, IaC templates).
☐	Update tracking metrics in the Finding Management Tool.
☐	If an exception was filed, confirm it is logged with an expiration date.

11. References

- Wiz Cloud Configuration Findings Documentation
- CSA CCM v4.0.5 Cargill Framework (Wiz)
- CSA Cloud Controls Matrix
- Cloud Security Navigator (CSN)
- Wiz CSPM Exception Governance
- CSPM Finding Management Tool